

Auditoría de cumplimiento PCI-DSS v4.0.1

Host: **f15-bench-target** · Fecha: 2026-04-15 21:18 · Alcance: Secciones 2, 6, 8, 10 (6 controles críticos)

Hash reproducibilidad: 606b172210936e9332b3261a2d7e7318a13c729c56f436c5b24504556c31a763

Separación de responsabilidades: los veredictos (PASS/FAIL/N/A/ERROR) y la evidencia (comando ejecutado + output raw) provienen de motores determinísticos reproducibles. Las secciones marcadas **LLM NARRATIVA** son prosa explicativa generada por modelo de lenguaje y no modifican los veredictos ni la evidencia. Para defensibilidad regulatoria, el auditor debe basarse en la evidencia determinística.

Resumen ejecutivo

Se ejecutaron **6** controles PCI-DSS v4 sobre el host. Resultados: **6 FAIL**, **0 PASS**, 0 N/A, 0 ERROR.

Control	Título	Sección	Veredicto	Severidad
2.2.2	Vendor default accounts	2	FAIL	CRITICAL
10.2.1	Audit trails	10	FAIL	HIGH
2.2.7	Non-console administrative access encryption	2	FAIL	HIGH
6.3.3	Critical security patches within 30 days	6	FAIL	HIGH
6.4.1	Public-facing web application protection	6	FAIL	HIGH
8.3.6	Minimum password complexity	8	FAIL	HIGH

Hallazgos

PCI 2.2.2 — Vendor default accounts

FAIL

Sección 2 · Severidad CRITICAL · Host f15-bench-target

Evidencia determinística

Comando ejecutado: `awk /etc/shadow ; mysql -u root -e 'SELECT 1' ; snmpwalk -c public`

Hallazgos estructurados:

```
{
  "shadow_empty_password_accounts": [
    "badacct"
  ],
  "mysql_root_empty": "N/A",
  "snmp_public_responds": "N/A",
  "sub_verdicts": {
    "shadow": "FAIL",
    "mysql": "N/A",
    "snmp": "N/A"
  }
}
```

Remediación determinística (texto de la regla)

Remove or lock any empty-password account. Set MySQL root password. Change SNMP community from 'public'.

Contexto (LLM)

LLM NARRATIVA El control 2.2.2 de PCI DSS v4 es crítico para entornos bancarios que manejan datos de titulares de tarjetas, ya que las cuentas con contraseñas vacías representan una vulnerabilidad de acceso no autorizado que puede ser explotada por atacantes para obtener privilegios de sistema. En un entorno bancario, donde la seguridad de los datos es fundamental, estas cuentas pueden permitir el acceso a sistemas críticos sin autenticación. La falla en este control indica un riesgo significativo de compromiso de la infraestructura de procesamiento de pagos.

Detalle de remediación (LLM)

LLM NARRATIVA Para eliminar cuentas con contraseñas vacías, se debe utilizar el comando 'passwd -l' para bloquear temporalmente la cuenta 'badacct' o 'userdel' para eliminarla completamente del sistema. La contraseña del usuario root de MySQL debe ser establecida mediante 'mysqladmin -u root password' seguido de una contraseña segura generada según las políticas de contraseñas de la organización. Para el servicio SNMP, se debe modificar el archivo de configuración para cambiar la comunidad 'public' a una cadena de texto compleja y única, generalmente ubicada en /etc/snmp/snmpd.conf.

PCI 10.2.1 — Audit trails

FAIL

Sección 10 · Severidad HIGH · Host f15-bench-target

Evidencia determinística

Comando ejecutado: `systemctl is-active auditd ; cat /etc/audit/rules.d/*.rules`

Hallazgos estructurados:

```
{
  "auditd_active": false,
  "rules_found": false,
  "issues": [
    "auditd not installed"
  ]
}
```

Remediación determinística (texto de la regla)

Install and enable auditd. Add PCI rules: -w /etc/passwd, /etc/shadow, /etc/sudoers; execve tracking.

Contexto (LLM)

LLM NARRATIVA El control 10.2.1 de trazas de auditoría es fundamental en entornos bancarios y de datos de titulares de tarjetas, ya que permite el monitoreo y registro de actividades críticas que pueden afectar la seguridad de la información. La falta de un sistema de auditoría activo como auditd impide la detección oportuna de accesos no autorizados o modificaciones de archivos sensibles. Este fallo representa un riesgo alto para la integridad y confidencialidad de los datos de pago.

Detalle de remediación (LLM)

LLM NARRATIVA La implementación de auditd requiere instalar el paquete correspondiente y habilitarlo para su ejecución automática al inicio del sistema. Los archivos críticos como /etc/passwd, /etc/shadow y /etc/sudoers deben ser monitoreados mediante reglas de vigilancia (-w) para registrar cualquier acceso o modificación. Además, se debe configurar el seguimiento de ejecución de procesos (execve tracking) para registrar todos los comandos ejecutados en el sistema.

PCI 2.2.7 — Non-console administrative access encryption

FAIL

Sección 2 · Severidad HIGH · Host f15-bench-target

Evidencia determinística

Comando ejecutado: sshd -T

Hallazgos estructurados:

```
{
  "permit_root_login": "yes",
  "max_auth_tries": "10",
  "protocol": "",
  "ciphers_present_weak": [
    "aes128-cbc",
    "aes256-cbc"
  ],
  "issues": [
    "MaxAuthTries=10",
    "PermitRootLogin=yes",
    "weak_ciphers=['aes128-cbc', 'aes256-cbc']"
  ]
}
```

Remediación determinística (texto de la regla)

Edit /etc/ssh/sshd_config: PermitRootLogin no, MaxAuthTries 4, modern Ciphers (no CBC). Reload sshd.

Contexto (LLM)

LLM NARRATIVA El control 2.2.7 establece que todo el acceso administrativo que no sea por consola debe estar cifrado para proteger los datos de los titulares de tarjetas en entornos bancarios. La configuración actual permite el inicio de sesión como root y utiliza cifrados débiles como aes128-cbc y aes256-cbc, lo cual representa un riesgo significativo para la confidencialidad de la información sensible. Este fallo permite que los atacantes exploren métodos de fuerza bruta más fácilmente y accedan a sistemas críticos sin protección adecuada.

Detalle de remediación (LLM)

LLM NARRATIVA La configuración recomendada implica modificar el archivo /etc/ssh/sshd_config para deshabilitar el inicio de sesión como root, limitar los intentos de autenticación y utilizar solo cifrados modernos. Es necesario establecer PermitRootLogin no para evitar el acceso directo con credenciales privilegiadas, y MaxAuthTries 4 para reducir la exposición a ataques de fuerza bruta. Además, se deben eliminar los cifrados CBC de la lista de cifrados permitidos y recargar el servicio sshd para aplicar los cambios de forma efectiva.

PCI 6.3.3 — Critical security patches within 30 days

FAIL

Sección 6 · Severidad HIGH · Host f15-bench-target

Evidencia determinística

Comando ejecutado: `apt list --upgradable ; grep 'upgrade' /var/log/dpkg.log*`

Hallazgos estructurados:

```
{
  "security_updates_pending": 1,
  "last_upgrade_age_days": 45,
  "reason": "1 security update(s) pending"
}
```

Remediación determinística (texto de la regla)

Enable unattended-upgrades and apply pending security patches.

Contexto (LLM)

LLM NARRATIVA El control 6.3.3 es fundamental en entornos financieros que manejan datos de titulares de tarjetas, ya que las vulnerabilidades no corregidas pueden ser explotadas por atacantes para acceder a información sensible. La demora en aplicar parches de seguridad representa un riesgo directo para la integridad y confidencialidad de los datos de pago. Cumplir con este control dentro del plazo de 30 días es esencial para mantener la protección de los sistemas críticos.

Detalle de remediación (LLM)

LLM NARRATIVA Habilitar unattended-upgrades permite la instalación automática de parches de seguridad sin intervención manual. Esta configuración debe ser implementada en todos los servidores y sistemas operativos críticos del entorno. La aplicación de los parches pendientes debe realizarse inmediatamente siguiendo los procedimientos establecidos para garantizar el cumplimiento del control.

PCI 6.4.1 — Public-facing web application protection

FAIL

Sección 6 · Severidad HIGH · Host f15-bench-target

Evidencia determinística

Comando ejecutado: curl -sI (each of ports [80])

Hallazgos estructurados:

```
{
  "exposed_web_ports": [
    80
  ],
  "per_port": {
    "80": {
      "scheme": "http",
      "missing_headers": [
        "content-security-policy",
        "x-content-type-options",
        "x-frame-options"
      ],
      "present_headers": []
    }
  }
}
```

Remediación determinística (texto de la regla)

Add HSTS, CSP, X-Frame-Options: DENY, X-Content-Type-Options: nosniff at web server layer.

Contexto (LLM)

LLM NARRATIVA El control 6.4.1 es fundamental para entornos bancarios que manejan datos de titulares de tarjetas, ya que las aplicaciones web expuestas a internet representan una de las principales vías de ataque para los atacantes. La falta de protección adecuada en puertos públicos como el puerto 80 HTTP expone directamente la infraestructura a vulnerabilidades conocidas que pueden ser explotadas para comprometer la integridad y confidencialidad de los datos sensibles. Este fallo representa un riesgo alto de violación de la seguridad de los datos de los titulares de tarjetas.

Detalle de remediación (LLM)

LLM NARRATIVA La implementación de encabezados de seguridad como HSTS, CSP y X-Frame-Options: DENY debe realizarse a nivel del servidor web para proteger contra ataques de tipo clickjacking y cross-site scripting. El encabezado X-Content-Type-Options: nosniff debe ser configurado para prevenir la ejecución de contenido malicioso que se intente disfrazar como tipos de archivo seguros. Estos encabezados deben ser aplicados de forma consistente en todas las respuestas HTTP generadas por el servidor web para garantizar una protección completa.

PCI 8.3.6 — Minimum password complexity

FAIL

Sección 8 · Severidad HIGH · Host f15-bench-target

Evidencia determinística

Comando ejecutado: cat /etc/login.defs ; cat /etc/security/pwquality.conf ; cat /etc/pam.d/common-password

Hallazgos estructurados:

```
{
  "login_defs_pass_min_len": null,
  "pwquality_minlen": null,
  "pwquality_minclass": null,
  "pam_pwquality_present": false,
  "issues": [
    "PASS_MIN_LEN not set in /etc/login.defs",
    "no pam_pwquality/pam_cracklib in /etc/pam.d/common-password",
    "pwquality.conf missing or unconfigured"
  ]
}
```

Remediación determinística (texto de la regla)

Set PASS_MIN_LEN 12 in /etc/login.defs. Configure pwquality.conf minlen=12, minclass=3. Enable pam_pwquality.

Contexto (LLM)

LLM NARRATIVA El control 8.3.6 de complejidad mínima de contraseñas es crucial en entornos financieros que manejan datos de titulares de tarjetas, ya que las contraseñas débiles representan una vulnerabilidad significativa para el acceso no autorizado a sistemas críticos. La falta de configuración adecuada de longitud mínima y clases de caracteres en los sistemas operativos permite que los atacantes exploiten credenciales débiles para comprometer el entorno de procesamiento de pagos. Este fallo de configuración incrementa el riesgo de brechas de seguridad que podrían afectar directamente la integridad y confidencialidad de los datos de los clientes.

Detalle de remediación (LLM)

LLM NARRATIVA Para cumplir con el control, se debe establecer PASS_MIN_LEN=12 en el archivo /etc/login.defs para definir la longitud mínima de las contraseñas. Además, es necesario configurar el archivo /etc/security/pwquality.conf con los parámetros minlen=12 y minclass=3 para exigir al menos 3 tipos diferentes de caracteres. La implementación requiere habilitar el módulo pam_pwquality en /etc/pam.d/common-password para que las políticas de complejidad se apliquen efectivamente durante el proceso de autenticación.

Apéndice A — Evidencia cruda

Comandos ejecutados y output stdout/stderr sin procesar. Permite reproducir manualmente cada hallazgo.

PCI 2.2.2 — Vendor default accounts

Comando

```
awk /etc/shadow ; mysql -u root -e 'SELECT 1' ; snmpwalk -c public
```

stdout (raw)

```
=== shadow ===  
badacct  
  
=== mysql ===  
mysql client not installed  
=== snmp ===  
snmpwalk not installed
```

stderr (raw)

```
(vacío)
```

PCI 10.2.1 — Audit trails

Comando

```
systemctl is-active auditd ; cat /etc/audit/rules.d/*.rules
```

stdout (raw)

```
auditd not installed or non-systemd init
```

stderr (raw)

```
(vacío)
```

PCI 2.2.7 — Non-console administrative access encryption

Comando

```
sshd -T
```

stdout (raw)

```
port 22  
addressfamily any  
listenaddress [::]:22  
listenaddress 0.0.0.0:22  
usepam yes  
loggingracetime 120  
x11displayoffset 10  
maxauthtries 10  
maxsessions 10  
clientaliveinterval 0  
clientalivecountmax 3  
streamlocalbindmask 0177  
permitrootlogin yes  
ignorerhosts yes  
ignoreuserknownhosts no
```



```

hostbasedauthentication no
hostbasedusesnamefrompacketonly no
pubkeyauthentication yes
kerberosauthentication no
kerberosorlocalpasswd yes
kerberosticketcleanup yes
gssapiauthentication no
gssapicleanupcredentials yes
gssapikeyexchange no
gssapistrictacceptorcheck yes
gssapistorecredentialsonrekey no
gssapikexalgorithms gss-group14-sha256-,gss-group16-sha512-,gss-nistp256-sha256-,gss-
curve25519-sha256-,gss-group14-sha1-,gss-gex-sha1-
passwordauthentication yes

```

```

kbdinteractiveauthentication no

```

stderr (raw)

```

printlastlog yes
x11useforwarding yes
x11uselocalhost yes

```

PCI 6.3.3 — Critical security patches within 30 days

Comando

```

permittedcommissions yes
strictmodes yes
tcpkeepalive yes
peremptypasswords no
apt-list-upgradable ; grep 'upgrade' /var/log/dpkg.log*
compression yes
gatewayports no

```

stdout (raw)

```

allowtcpforwarding yes
allowagentforwarding yes
disableforwarding yes
allowstreamlocalforwarding yes
$SSH_STEM$ jammy-updates, jammy-security 3.0.2-0ubuntu1.23 amd64 [upgradable from:
$SSH_STEM$ jammy-updates 249.11-0ubuntu3.20 amd64 [upgradable from: 249.11-0ubuntu3.17]
$SSH_STEM$ jammy-updates 249.11-0ubuntu3.20 amd64 [upgradable from: 249.11-0ubuntu3.17]
$SSH_STEM$ jammy-updates 249.11-0ubuntu3.20 amd64 [upgradable from: 249.11-0ubuntu3.17]
exposeauthinfo no
pidfile /run/sshd.pid
modulelist /etc/ssh/moduli
$SSH_STEM$ libcrypto2.0.0 amd64 3.0.2-0ubuntu1.23 amd64 [upgradable from: 3.0.2-0ubuntu1.23]
$SSH_STEM$ libcrypto2.0.0 amd64 3.0.2-0ubuntu1.23 amd64 [upgradable from: 3.0.2-0ubuntu1.23]
$SSH_STEM$ libcrypto2.0.0 amd64 3.0.2-0ubuntu1.23 amd64 [upgradable from: 3.0.2-0ubuntu1.23]
ciphers aes128-cbc,aes256-cbc,aes256-gcm@openssh.com

```

stderr (raw)

```

macs umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-
sha2-512-etm@openssh.com,hmac-sha1-

```

```

etm@openssh.com,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1
(unsafe) none

```

```

forcecommand none

```

PCI 6.4.1 — Public-facing web application protection

Comando

```

securitykeyprovider internal
authorizedprincipalsfile /etc/ssh/authorized_principals
curl -sI (each of ports [80])
versionaddendum none

```

stdout (raw)

```

authorizedkeyscommand none
authorizedkeyscommanduser none
authorizedprincipalscommand none
authorizedprincipalscommanduser none
HTTP/1.1 200 OK
Server: Apache/2.4.18 (Ubuntu)
Date: Wed, 15 Apr 2026 21:04:39 GMT
Content-Type: text/html
Content-Length: 39
Last-Modified: Wed, 15 Apr 2026 21:04:39 GMT
Connection: keep-alive
ETag: "69dffd67-27"

```

```
Accept-Ranges: bytes
```

stderr (raw)

```
(vacío)
```

PCI 8.3.6 — Minimum password complexity

Comando

```
cat /etc/login.defs ; cat /etc/security/pwquality.conf ; cat /etc/pam.d/common-password
```

stdout (raw)

```
=== login.defs (PASS_MIN_LEN) ===  
PASS_MIN_LEN=None  
  
=== pwquality.conf ===  
minlen=None  
minclass=None  
  
=== pam.d/common-password has pam_pwquality: no ===
```

stderr (raw)

```
(vacío)
```

Este reporte se considera válido únicamente acompañado del artifact JSON cuyo SHA-256 coincide con 606b172210936e9332b3261a2d7e7318... Cualquier modificación del JSON invalida este reporte. Generado por Kryon compliance engine F15.1.